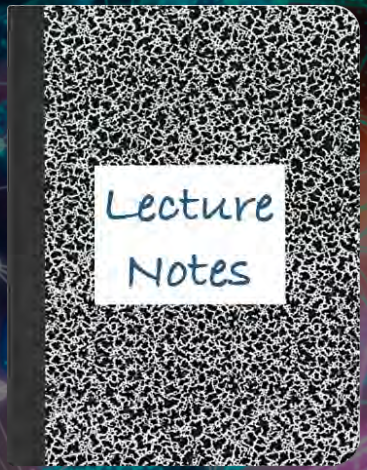
CS 419: Computer Security

Week 1: Part 2

Vulnerabilities, Exploits, Attacks



Paul Krzyzanowski

© 2022-2025 Paul Krzyzanowski. No part of this content may be reproduced or reposted in whole or in part in any manner without the permission of the copyright owner.

Definitions

Vulnerability

A weakness in the implementation or operation of a system that can be exploited: a bad policy or a bug

Exploit

Software, commands, or instructions to take advantage of a vulnerability

Attack Vector

The type of attack – the technique that's used to attack the system (e.g., email attachment, network, website)

Attack (cyberattack)

The active use of an exploit via the attack vector to subvert security policies and mechanisms

Threat

Any circumstance or event that can cause harm

Threat Actor

The agent who may carry out the attack

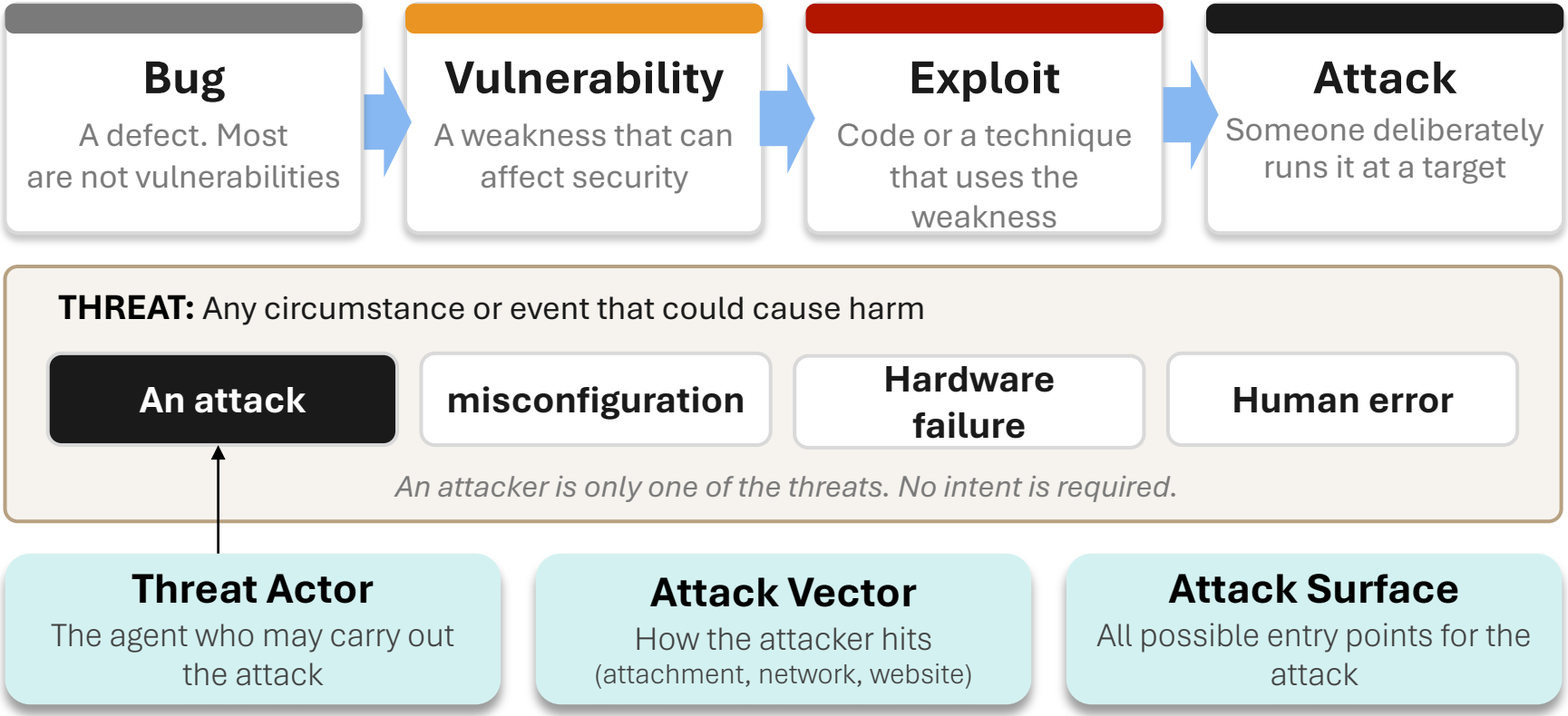
Attack surface

All possible entry points in the system – all the attack vectors in the system

We need to be aware of the attack surface of an environment

- Otherwise, we don't know what to defend
- If possible, **reduce the attack surface**: that way, there will be less we need to protect

Vulnerability, Exploit, Attack, And Threat



Vulnerabilities

- **Failures in the system: policies or mechanisms**
  - Bugs that can affect the security of a system
- **Common vulnerabilities:**

Assumptions about input lengths, existence of files, success of system calls

Insecure state
Use of default passwords, accessible hardware, insecure services

Buggy protocols
that may allow interception, impersonation, downgrading versions

Outdated cryptography
Short encryption keys or cryptographic algorithms where weaknesses have been found

Some vulnerabilities can be old

Nine-Year-Old RefluXFS Linux Flaw Gives Local Users Root on Default RHEL Installs

The Hacker News

Swati Khandelwal • July 23, 2026

RefluXFS, a Linux kernel flaw disclosed on July 22 and tracked as CVE-2026-64600, lets an unprivileged local user overwrite root-owned files on an XFS filesystem and gain persistent root access.

Qualys said default installations of Red Hat Enterprise Linux and its derivatives, Fedora Server, and Amazon Linux can meet the conditions for exploitation.

The company demonstrated the race against /etc/passwd and setuid-root binaries. The overwrite lands at the block layer. It survives a reboot and leaves the target's ownership, permissions, timestamps, and setuid bit untouched, so a modified setuid-root binary still runs as root.

Discovered in 2026 – Around since 2017

https://thehackernews.com/2026/07/nine-year-old-refluxfs-linux-flaw-gives.html

Some vulnerabilities can be old

CISA Adds Five-Year-Old jQuery XSS Flaw to Exploited Vulnerabilities List

The Hacker News

Ravie Lakshmanan • Jan 24, 2025

The U.S. Cybersecurity and Infrastructure Security Agency (CISA) on Thursday placed a now-patched security flaw impacting the popular jQuery JavaScript library to its Known Exploited Vulnerabilities (KEV) catalog, based on evidence of active exploitation.

The medium-severity vulnerability is CVE-2020-11023 (CVSS score: 6.1/6.9), a nearly five-year-old cross-site scripting (XSS) bug that could be exploited to achieve arbitrary code execution.

"Passing HTML containing <option> elements from untrusted sources - even after sanitizing them - to one of jQuery's DOM manipulation methods (i.e. .html(), .append(), and others) may execute untrusted code," according to a GitHub advisory released for the flaw.

Discovered in 2025 – Around since 2020

https://thehackernews.com/2025/01/cisa-adds-five-year-old-jquery-xss-flaw.html

This one was 18 years old

Chrome, Safari and other browsers vulnerable to 0.0.0.0 Day vulnerability — what you need to know

tom's HARDWARE

This critical vulnerability laid dormant for 18 years but can now be used by hackers in their attacks

Anthony Spadafora • August 8, 2024

It's not every day that we come across a vulnerability that's almost two decades old but cybersecurity researchers have discovered a new zero-day flaw that impacts all major browsers.

As reported by The Hacker News, the Israeli app security firm Oligo found what it's calling a "0.0.0.0 Day" that can be exploited by hackers to access sensitive services running on local devices. The most surprising thing about this critical vulnerability though is that it has laid dormant in popular browsers for 18 years.

The 0.0.0.0 Day impacts all of the top browsers including Google Chrome and other Chromium-based browsers like Edge, Safari and Firefox. However, it's worth noting that it only affects devices running macOS and Linux. The reason why the best Windows laptops aren't affected is due to the fact that Microsoft blocks this IP address at the operating system level.

https://www.tomsguide.com/computing/online-security/chrome-safari-and-other-browsers-vulnerable-to-0000-day-vulnerability-what-you-need-to-know

Lots of systems don’t get updated

Old vulnerabilities that were fixed are still out there

- **Laziness:** *why bother?*
- **Lack of knowledge**
  - On how to fix the software … or that the vulnerability exists
- **Fear of breaking something that works**
  - Especially critical components like industrial control equipment
- **Inability to upgrade embedded systems**
  - Some devices weren’t designed to support updates
- **Lack of manufacturer support for updates**
  - Old routers, TV sets, printers, security cameras, and computers
  - Old software, because you don’t want to pay for new versions

Systems Are Vulnerable to Unpatched Vulnerabilities

- **A vulnerability does not disappear when a patch is released.**
  - It disappears only when the patch is deployed.
- **Median time from detection to full remediation: 43 days**
- **Nearly half of vulnerabilities can remain unresolved after a year**
- **IoT/OT devices may remain on vulnerable firmware for 5–10+ years**

Attackers can begin exploiting vulnerabilities the day they are disclosed

Attacker

Hours or days

Defender

Weeks, months, or years

Lots of Systems Don’t Get Updated

Hackers are using this old trick to dodge security protections

CVE-2015-2291 is a years-old security vulnerability - but cyber criminals are still able to take advantage of unpatched systems to compromise networks.

Danny Palmer • January 13, 2023

Cyber criminals are exploiting an old vulnerability in Intel drivers in an attempt to gain access to networks in a way that allows them to bypass cybersecurity protections.

...

Once inside a network, Scattered Spider uses a technique that CrowdStrike describes as 'Bring Your Own Vulnerable Driver' (BYOVD), which targets loopholes in Windows security.

While Microsoft attempts to limit the capabilities of malware gaining access to systems by preventing unsigned kernel-mode drivers to be run by default, attackers can get around this with BYOVD, which enables them to install a legitimately signed but malicious driver to carry out attacks.

...

One of the ways they do this operation as stealthily as possible is by not using malware, but instead installing a range of legitimate remote access tools to ensure persistence on the compromised system.

According to analysis by CrowdStrike, the attackers are delivering malicious kernel drivers through a vulnerability in the Intel Ethernet diagnostics driver for Windows (tracked as CVE-2015-2291).

https://www.zdnet.com/article/hackers-are-using-this-old-trick-to-dodge-security-protections/

Russian Hackers Hitting Critical Infrastructure, FBI Warns

GOVINFO SECURITY®

State-Sponsored Espionage Group Tied to Exploits of No-Longer-Supported Cisco Gear

Matthew J. Schwartz • August 21, 2025

Russian intelligence hackers are using obsolete and unpatched equipment made by networking mainstay Cisco Systems to further stealthy and ongoing cyberespionage operations, the U.S. federal government warned Wednesday.

The FBI in an advisory report said hackers from the Federal Security Service - the FSB, the Russian successor to the KGB - are targeting the United States and allies IT and operational technology environments.

For at least the past year, the hackers have been "collecting configuration files for thousands of networking devices associated with U.S. entities across critical infrastructure sectors" and using the files to gain authorized access to the networking equipment, the bureau said. "The actors used the unauthorized access to conduct reconnaissance in the victim networks, which revealed their interest in protocols and applications commonly associated with industrial control systems."

The U.S. government attributes the attacks to an FSB unit known as Center 16. The group exploits a vulnerability in the Smart Install feature of Cisco devices, tracked as CVE-2018-0171, which attackers can use to execute arbitrary code on a device.

https://www.govinfosecurity.com/russian-hackers-hitting-critical-infrastructure-fbi-warns-a-29268

Lots of Systems Don’t Get Updated

Nation state hackers exploited years-old bug to breach a US federal agency

TechCrunch

Carly Page • March 16, 2023

The U.S. government has warned that multiple cybercriminal gangs, including a nation state-backed hacking group, exploited a four-year-old software vulnerability in order to compromise a U.S. federal government agency.

A joint alert released by the CISA, the FBI and the Multi-State Information Sharing and Analysis Center (known as MS-ISAC) on Wednesday revealed that hackers from multiple hacking groups exploited known vulnerabilities in Telerik, a user interface tool for web servers. This software — designed for building components and themes for web applications — was running on the U.S. agency’s internet-facing web server.

https://techcrunch.com/2023/03/16/cisa-nation-state-hackers-breach-federal-agency/

Exploits

Exploit: figuring out how to use the vulnerability in an attack

- **EternalBlue: an exploit that targeted a vulnerability in Windows file sharing**
  - Developed by the NSA
  - Leaked by the Shadow Brokers group in April 2017
- **Microsoft patched the vulnerability in March, a month before the leak**
- **WannaCry used it in May • NotPetya used it in June**

A vulnerability is a property of the system

An exploit is something someone built

The patch was available before the exploit was public
but hundreds of thousands of machines got attacked

Kinds Of Attack

Ransomware	Disable access to data, demand payment to restore it
Extortion	Demand payment under threat, such as publishing stolen data
Double extortion	Encrypt and also threaten to publish
Denial of service	Exhaust a finite resource, or trigger a crash
Resource hijacking	Run software on someone else's machine
Impersonation and social engineering	Use credentials or use a person

Ransomware Is An Industry

- **About $820 million in crypto ransom payments, down 8%**
- **Only 28% of victims paid**
- **Median payment: $59,556, up from $12,738 in 2024**
  - 368% increase in the median

Fewer victims are paying

The ones who pay are much larger

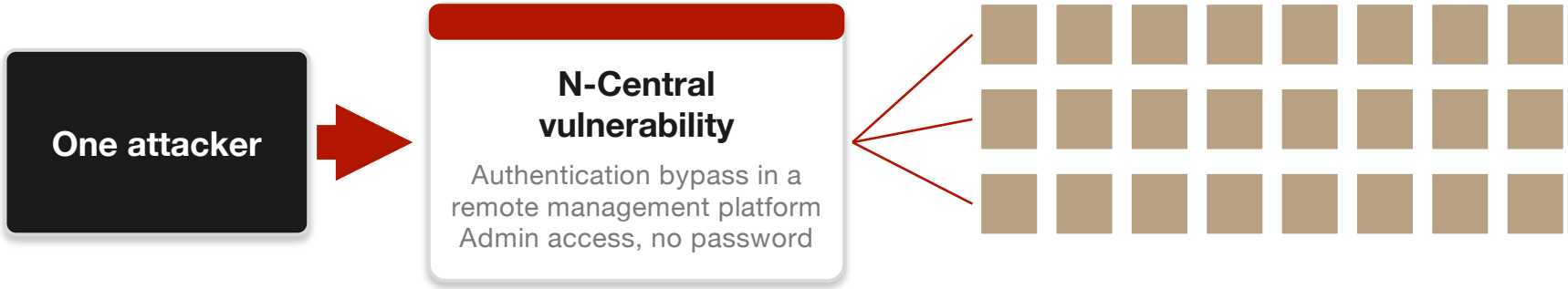
The business adapted to target bigger victims

Attack Vectors and the N-Central Example

Common vectors

Email attachment | Malicious website | USB device | Reachable network service | Stolen credentials

July-August 2026: N-able N-central attack



Threat actors actively exploited an authentication bypass vulnerability in remote management & monitoring software. Attacking one server gave an attacker control of many clients.

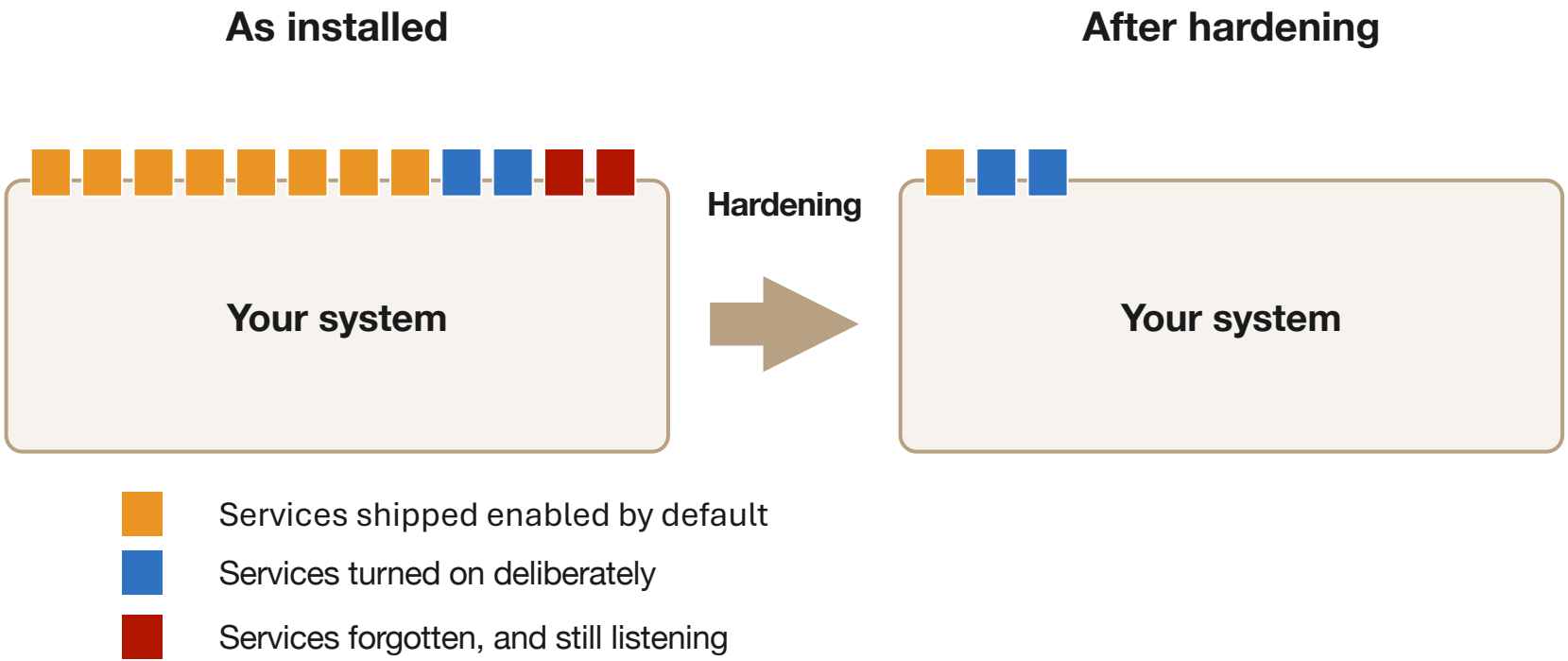
One vector, many victims

July 26-27 2026: Water Utilities Attack

More than 30 Minnesota community water systems attacked

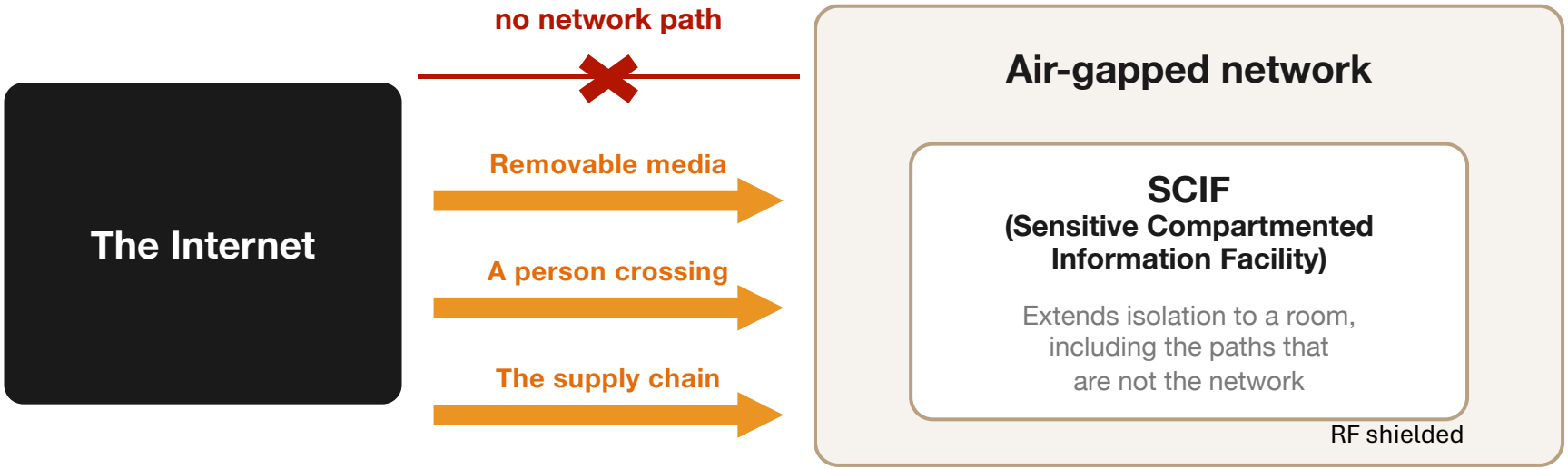
- **Attackers reach Internet-facing programmable logic controllers**
  - Mostly through default passwords and exposed remote access tools
- **They change the controllers' IP addresses and passwords**
  - Operators are locked out of their own plants
- **This happened again in at least 12 other states in August**

Attack Surface and Hardening



An attacker cannot reach a service that is not running

Reducing an Attack Surface via Isolation



Isolation reduces the paths. It does not eliminate them.
Natanz was air gapped. Malicious software still reached it.

Threats

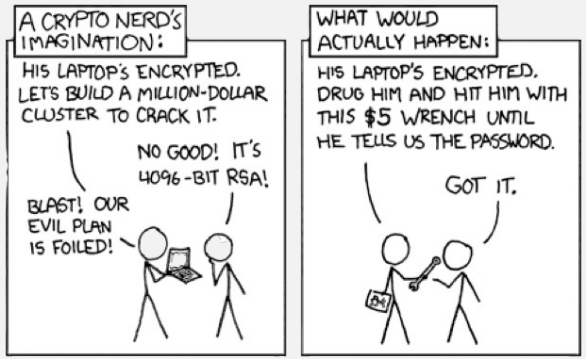
Threat categories

- **Disclosure: Unauthorized access to data**
  - Snooping (wiretapping)
- **Deception: Acceptance of false data**
  - Injection of data, modification of data, denial of receipt
- **Disruption: Interruption or prevention of correct operation**
  - Denial of service, data deletion, or modification
- **Usurpation: Unauthorized control of some part of a system**
  - May lead to modification, spoofing, delay, denial of service

The Human Factor

- **Social engineering**
  - Deception: getting someone to do something against their best interests
- **Laziness**
  - Finding ways to bypass or weaken security mechanisms
  - Storing passwords in unencrypted files, forgetting passwords, staying logged in
- **Curiosity**
  - Snooping coworker's data
  - Plugging in the USB flash drive you found
- **Honest mistakes**
  - Misconfiguring a service, writing buggy code, accidentally deleting a file

Attackers can often resort to the **three Bs: Burglary**, **Bribery**, or **Blackmail**

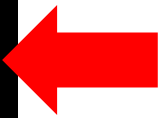


People Make Mistakes

January 2025: DNS configuration error at MasterCard
Present for almost five years!

```
;; AUTHORITY SECTION:
az.mastercard.com.      3600    IN      NS      a1-29.akam.net.
az.mastercard.com.      3600    IN      NS      a7-67.akam.net.
az.mastercard.com.      3600    IN      NS      a22-65.akam.ne.
az.mastercard.com.      3600    IN      NS      a26-66.akam.net.
az.mastercard.com.      3600    IN      NS      a9-64.akam.net.

;; Query time: 92 msec
;; SERVER: 216.119.218.53#53(dns1.mastercard.com) (TCP)
;; WHEN: Fri Jan 10 11:24:51 EST 2025
;; MSG SIZE  rcvd: 191
```



https://krebsonsecurity.com/2025/01/mastercard-dns-error-went-unnoticed-for-years/

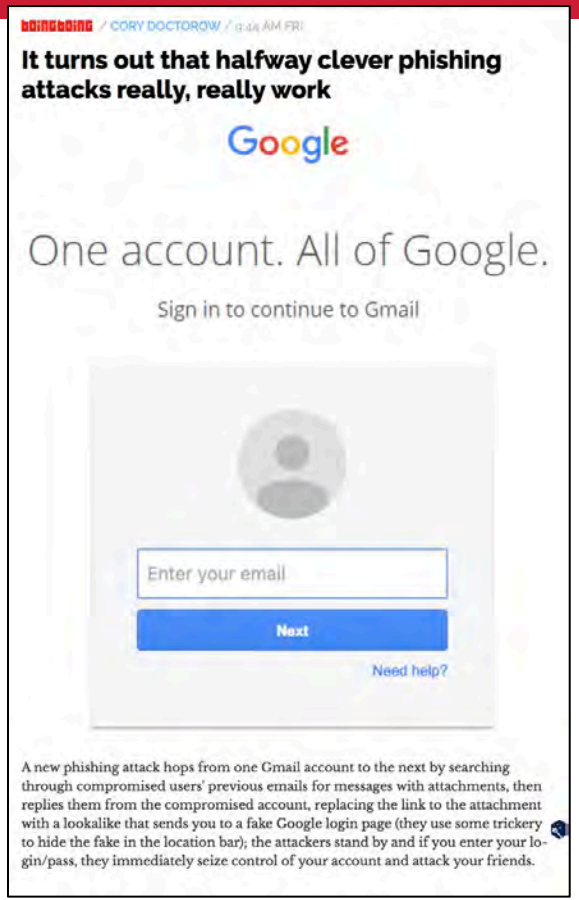
Don’t underestimate the human element

Humans are

- Bad at storing keys
- Poor at estimating risk
- Not accurate
- Careless
- Gullible



https://xkcd.com/1777/



Social engineering is the top threat

But don’t blame the user

It’s not the user’s fault if they click on a link and it infects their system.

It’s not their fault if they plug in a strange USB drive or ignore a warning message that they can’t understand.

It’s not even their fault if they get fooled by a look-alike bank website and lose their money.

The problem is that we’ve designed these systems to be so insecure that regular, nontechnical people can’t use them with confidence.

We’re using security awareness campaigns to cover up bad system design.

— Bruce Schneier, May 28, 2025

https://www.darkreading.com/cybersecurity-operations/why-take9-will-not-improve-cybersecurity

Coinbase says cyberattack cost up to $400 million after bribed overseas employees stole customer data

MarketWatch

Crypto-trading company said clients were already informed of the breach, which may cost it up to $400 million based on current estimates.

By Steve Gelsi | May 15, 2025



Coinbase Global Inc. said Thursday it's working with law enforcement to track down an unknown "threat actor" that paid its contractors working in support roles for the company outside the U.S. to obtain personal information about its customer base.

Coinbase did not say how many of its clients were affected, but it had already informed them about the breach after it detected it months ago and fired the contractors involved.

"The threat actor appears to have obtained this information by paying multiple contractors or employees working in support roles outside the United States to collect information from internal Coinbase systems to which they had access in order to perform their job responsibilities," the company said.

https://www.marketwatch.com/story/coinbase-suffers-cyber-attack-as-oversees-employees-were-bribed-to-steal-customer-data-c74b2840

AT&T employees took bribes to plant malware on the company's network

DOJ charges Pakistani man with bribing AT&T employees more than $1 million to install malware on the company's network, unlock more than 2 million devices.

By Catalin Cimpanu for Zero Day | August 6, 2019 -- 14:02 GMT (07:02 PDT) | Topic: Security



AT&T employees took bribes to unlock millions of smartphones, and to install malware and unauthorized hardware on the company's network, the Department of Justice said yesterday.

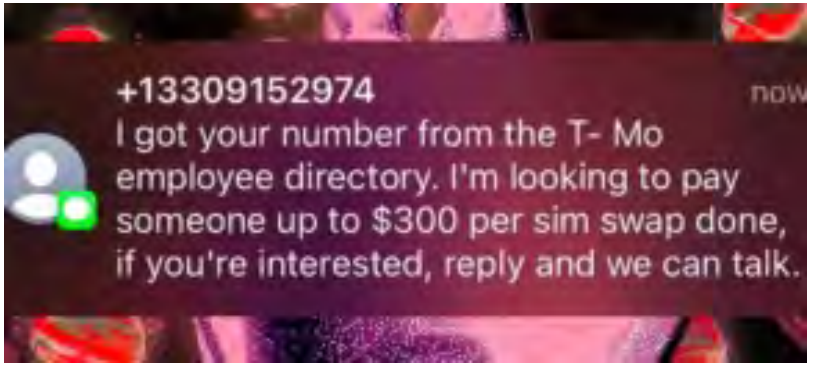
These details come from a DOJ case opened against Muhammad Fahd, a 34-year-old man from Pakistan, and his co-conspirator, Ghulam Jiwani, believed to be deceased.

SIM Swappers Try Bribing T-Mobile and Verizon Staff $300

Security Boulevard
POWERED BY Techstrong Group

DOJ charges Pakistani man with bribing AT&T employees more than $1 million to install malware on the company's network, unlock more than 2 million devices.

By Richi Jennings | April 16, 2024



It's no secret that cellular carrier reps are subject to bribery. Here's a great example. Yes, again with the SIM swapping—where a fraudster convinces a representative to move a target's line to a new SIM because they "lost" their phone.

Someone seems to have stolen a contact list of

T-Mobile employees and is texting them offers of bribes to execute SIM swaps. But T-Mobile denies it's been hacked… again.

Here's the soft underbelly of the insider threat model. In today's SB Blogwatch, we balk at the three-Benjamin bribes.

https://securityboulevard.com/2024/04/sim-swap-bribe-t-mobile-300-richixbw/

July 2020 Twitter (X) Breach



- **Hackers targeted 130 users**
- **Tweeted cryptocurrency scam from 45 accounts they were able to access**
  - Changing the email address & login credentials
- **Brought in $120,000**
- **Not a big deal … but could have been a lot worse**
  - X is used by political & business leaders
  - The right tweet can move markets or start conflicts

What happened?

Internal employee changed email addresses and turned off security features of certain high-profile accounts.

It wasn't social engineering, it was bribery — a Twitter employee was paid.

Insider threat problem: Twitter had almost 5,000 employees at the time.



https://www.theverge.com/2020/7/15/21326656/twitter-hack-explanation-bitcoin-accounts-employee-tools

Exclusive: More than 1,000 people at Twitter had ability to aid hack of accounts



Joseph Menn, Katie Paul, Raphael Satter • July 23, 2020

SAN FRANCISCO (Reuters) - More than a thousand Twitter employees and contractors as of earlier this year had access to internal tools that could change user account settings and hand control to others, two former employees said, making it hard to defend against the hacking that occurred last week.

Twitter said on Saturday that the perpetrators "manipulated a small number of employees and used their credentials" to log into tools and turn over access to 45 accounts. here On Wednesday, it said that the hackers could have read direct messages to and from 36 accounts but did not identify the affected users.

The former employees familiar with Twitter security practices said that too many people could have done the same thing, more than 1,000 as of earlier in 2020, including some at contractors like Cognizant.

https://www.reuters.com/article/us-twitter-cyber-access-exclusive/exclusive-more-than-1000-people-at-twitter-had-ability-to-aid-hack-of-accounts-idUSKCN24O34E

Threat Model

- **Set of assumptions about the abilities of an adversary**
- **A way to identify & prioritize potential threats from an attacker's point of view**
  - Think about things that could go wrong
  - Bad guys don't follow rules: they don't care about your policies
  - We need to understand what types of attacks are possible
- **Assess**
  - What's valuable?
  - Where will you be likely to be attacked?
  - What are the most significant threats?
- **Think about entities in the system, how they communicate & store data**
  - Where are the trust boundaries?
  - Where and how is protection enforced?

Incentives ⇒ Human factors

Security is as weak as its weakest link

People are often the weakest link in security

- Users may **masquerade** as another person if they can steal or guess access credentials
- **Corrupt insiders** are considered trusted and can get through most security measures
- Untrained people can make **honest mistakes** that compromise security
  - This includes untrained system administrators (bad configurations), poor programmers (poor implementations), and employees that abuse privileges (bad actions)

- **Social engineering is a powerful tactic**

  People tend to be trusting and usually try to help … that can backfire:
  - Convince someone to give you their credentials or access to the data you need
    - Get their ID/password, convince someone to let you into the building, impersonate yourself as someone else and they believe you ("*I work in IT and need your info*"), …

Security is an Investment

- **Security costs money**
  - Physical security: locks, guards, cameras, barbed wire, …
  - Computer security: skilled employees, specifications, design, implementation, penetration testing, protocol validation, etc.
- **Security provides no reward**
  - Designing a secure system costs extra money and takes more time
  - It does not make a system faster, easier to use, or function better
- **Economics impacts business decisions of how much effort to put into security**
  - People don't see the benefits directly, so security often does not get much attention
  - What is the value of the possible loss of reputation, money, intellectual property, etc. if there is a security breach?

Can we get insurance?

Can we add legal disclaimers?

Can we outsource?

Can we hope not to be attacked?

The End